

AI-Enabled OAuth Device Code Phishing Campaign

AI-Enabled OAuth Device Code Phishing Campaign

Threat Campaign Report

Field	Value
Classification	TLP:CLEAR
Published	2026-06-03
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Campaign / Identity Security Report

TLP:CLEAR | Lost Boys Cyber | AI-Enabled OAuth Device Code Phishing Campaign - Threat Campaign Report

Published: 2026-06-03 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Campaign Metadata
3. Source Review & Confidence
4. Threat Actor Profile
5. Campaign Timeline
6. Attack Chain / Methodology
7. Payload or Tooling Analysis
8. Related Activity
9. Indicators of Compromise
10. MITRE ATT&CK Mapping
11. Detection Engineering
12. Threat Hunting
13. Impact Assessment
14. Recommended Actions
15. Sources & References

1. Executive Summary

AI-enabled OAuth device-code phishing has moved from a niche identity-abuse technique into a repeatable phishing-as-a-service pattern against Microsoft 365 and Entra ID tenants. Microsoft reported an April 2026 campaign where attackers used AI-generated emails and device-code authentication flows to steal user tokens, bypass normal password collection, and obtain access without deploying malware. The FBI followed with a May 2026 public service announcement on Kali365, describing a phishing platform that uses AI and automation to craft convincing lures, spoof brands, and steal OAuth tokens through the legitimate Microsoft device-code workflow.

The campaign matters because it attacks identity controls at the consent and token layer. Users are not asked for a password on an attacker-controlled page; instead, they are pushed to a real Microsoft login page and tricked into entering a short device code generated by an attacker-controlled session. If the user completes the prompt, the attacker receives authenticated OAuth tokens and can access cloud resources as the victim. This technique can defeat many password-focused controls and can be difficult for users to recognize because the browser interaction occurs on legitimate Microsoft domains.

Confirmed facts:

- Microsoft reported an AI-enabled device-code phishing campaign on 2026-04-06.
- FBI IC3 issued a Kali365 PSA on 2026-05-21 describing AI-assisted phishing and OAuth-token theft against organizations.
- The attacker tradecraft abuses the OAuth 2.0 device authorization grant, a legitimate flow intended for devices without full browser or keyboard input.
- The primary victim platform is Microsoft 365 / Microsoft Entra ID.
- Observed objectives include token theft, mailbox access, data access, session persistence, and follow-on business email compromise or financial fraud.
- Campaigns increasingly use AI-generated lure text, fake brand assets, automated infrastructure, and phishing kits that operationalize OAuth abuse.

Analyst assessment:

- Treat this as a high-priority identity threat, not a commodity email nuisance.
- The durable detection surface is Entra ID sign-in, OAuth app, device-code, token, mailbox, and consent telemetry.
- Organizations that allow broad device-code authentication, weak conditional access, excessive OAuth app consent, or limited audit retention face elevated risk.

2. Campaign Metadata

Field	Assessment
Campaign name	AI-enabled OAuth device-code phishing
Related platform	Kali365 phishing-as-a-service, EvilProxy/Evilginx-style identity phishing ecosystem, device-code phishing tooling
First major reporting window	2025-2026 public reporting; Microsoft campaign report published 2026-04-06
Latest source refresh	2026-06-03
Primary targets	Microsoft 365 / Entra ID users, enterprises, helpdesk-heavy organizations, finance and executive workflows
Primary objective	OAuth token theft and cloud account access
Initial access vector	Phishing email, chat/social lure, fake meeting/collaboration workflow, device-code prompt
Malware required	No malware required for core compromise
Attribution	Unattributed criminal and PhaaS-enabled activity; specific operators vary
Confidence	High for technique and Microsoft 365 risk; Medium for specific campaign clustering across vendors

3. Source Review & Confidence

Source	Contribution	Confidence	Notes
Microsoft Security Blog, 2026-04-06	Primary reporting on AI-enabled device-code phishing campaign and defensive guidance for Microsoft environments	High	Core source for Microsoft 365 / Entra behavior.
FBI IC3 PSA260521, 2026-05-21	Public warning on Kali365, AI-assisted phishing, OAuth token theft, and business impact	High	Government source; validates operational risk.
Microsoft identity platform documentation	Defines OAuth 2.0 device authorization grant behavior	High	Primary reference for the legitimate protocol being abused.
CISA and NSA identity / cloud guidance	Defensive baseline for phishing-resistant MFA, conditional access, and cloud monitoring	High	General defensive control guidance, not campaign-specific.
MITRE ATT&CK	Technique taxonomy for phishing, valid accounts, cloud account abuse, and MFA-interception-adjacent behavior	High	Mapping reference.
Security vendor reporting on PhaaS and device-code phishing	Context on commoditization, phishing kits, and abuse patterns	Medium	Useful context; individual kit names and infrastructure can change quickly.

Source limitations:

- Public reporting often describes representative tradecraft but does not expose complete live infrastructure, victim counts, or tenant-specific telemetry.
- OAuth device-code phishing often leaves few file/network IOCs; behavioral cloud telemetry is more reliable than blocklists.
- “AI-enabled” describes lure generation, automation, and campaign scaling. It does not necessarily mean the phishing infrastructure uses autonomous AI agents after compromise.

4. Threat Actor Profile

No single threat actor owns this tradecraft. Public reporting points to a criminal ecosystem where phishing-as-a-service operators, initial access brokers, BEC crews, and financially motivated actors can use the same device-code technique.

Likely operator profile:

- Financially motivated criminal actors.
- PhaaS customers with limited infrastructure expertise.
- BEC and account-takeover operators.
- Initial access brokers seeking cloud-session footholds.
- Opportunistic actors targeting organizations with weak conditional access and OAuth governance.

Capabilities:

- Generate realistic email lures using AI-assisted writing and brand mimicry.
- Produce convincing Microsoft 365, Teams, SharePoint, OneDrive, DocuSign, HR, voicemail, or helpdesk-themed pretexts.

- Abuse legitimate Microsoft device login endpoints to reduce user suspicion.
- Harvest tokens without asking for passwords directly.
- Use stolen sessions for mailbox access, rule creation, data collection, lateral phishing, invoice fraud, and app consent abuse.

Attribution confidence:

- High confidence in financially motivated intent for most observed activity.
- Medium confidence that Kali365-style platforms are enabling lower-skilled actors.
- Low confidence in assigning any single intrusion to a named actor without tenant telemetry, kit artifacts, or infrastructure overlap.

5. Campaign Timeline

Date	Event	Confidence
2024-2025	Device-code phishing becomes more visible in Microsoft 365 identity attacks and red-team tooling discussions.	Medium
2025	PhaaS operators increasingly package adversary-in-the-middle, token theft, and identity phishing workflows.	Medium
2026-04-06	Microsoft publishes research on an AI-enabled device-code phishing campaign.	High
2026-05-21	FBI IC3 publishes PSA260521 on Kali365, warning about AI-generated phishing, brand spoofing, and OAuth token theft.	High
2026-06-03	This report refreshes public-source findings and defensive guidance.	High

6. Attack Chain / Methodology

6.1 Initial Lure

Attackers deliver an AI-generated lure by email or another collaboration channel. Common pretexts include:

- Microsoft Teams meeting or file review.
- Shared SharePoint or OneDrive document.
- Voicemail notification.
- HR policy update.
- IT helpdesk validation.
- MFA revalidation.
- Invoice or payment approval.
- Secure document portal.

AI enablement improves scale and quality:

- Faster creation of grammatically clean messages.
- Brand and department tone mimicry.
- Personalized text using public or breached data.
- Variant generation to evade static email rules.
- Localized language for different regions.

6.2 Device-Code Prompt

The attacker initiates an OAuth device authorization flow from their own infrastructure or tool. The flow returns:

- A `user_code`, often a short human-readable code.
- A verification URL, commonly a legitimate Microsoft device-login page.
- A polling interval where the attacker waits for authorization.

The lure instructs the victim to visit the verification page and enter the code. Because the page can be a legitimate Microsoft endpoint, the user may see expected branding and MFA prompts.

6.3 Token Acquisition

If the victim authenticates and enters the code:

- Microsoft completes the device authorization flow.
- Tokens are issued to the client session associated with the attacker's device-code request.
- The attacker obtains access tokens and possibly refresh tokens depending on client, scope, and tenant controls.
- The attacker may never see the user's password.

6.4 Cloud Access and Persistence

After token acquisition, the attacker may:

- Read mailbox contents.
- Search for invoices, payments, HR data, or sensitive documents.
- Create inbox rules to hide replies or forward mail.
- Access SharePoint, OneDrive, Teams, or Graph API resources.
- Register or abuse OAuth applications if consent controls are weak.
- Use compromised accounts to send internal phishing.
- Attempt BEC, payroll diversion, invoice fraud, or data theft.

6.5 Cleanup and Evasion

Observed and expected evasion patterns:

- Use legitimate Microsoft login and Graph endpoints.
- Avoid malware deployment.
- Rotate cloud-hosted infrastructure and phishing domains.
- Use residential proxy or VPN infrastructure.
- Reuse valid session tokens until revoked or expired.
- Avoid obvious impossible travel by operating near victim geography when possible.

7. Payload or Tooling Analysis

This campaign does not require a binary payload. The "payload" is the identity session.

7.1 OAuth Device Authorization Grant

The OAuth 2.0 device authorization grant is legitimate. It is designed for devices that cannot easily host a browser or collect complex input. In normal use, a device requests authorization and asks the user to complete login on another device.

Abuse condition:

- The user believes they are authorizing their own workflow.
- In reality, they authorize the attacker's waiting session.

7.2 Kali365 / PhaaS Enablement

The FBI's Kali365 PSA describes a platform that uses AI to generate convincing phishing content, spoof brands, harvest credentials or tokens, and automate follow-on targeting. The key defender takeaway is not one static tool name; it is that identity phishing is becoming productized and automated.

Expected platform features:

- Campaign builder for email templates.
- AI-assisted lure generation.
- Brand kit and logo spoofing.
- Hosted phishing pages or redirect chains.
- Token capture / session management.
- Victim tracking and delivery metrics.
- Integration with bulletproof or fast-rotating infrastructure.

7.3 OAuth Consent and App Abuse

Device-code phishing and OAuth consent phishing are adjacent but distinct:

- Device-code phishing tricks a user into authorizing an attacker's device/session.
- Consent phishing tricks a user or admin into granting a malicious application access to data.

Both can result in cloud access without traditional malware. Both should be covered by identity detections.

8. Related Activity

Related activity clusters:

- Adversary-in-the-middle phishing kits that proxy Microsoft 365 login and steal session cookies.
- OAuth consent phishing where attackers register malicious apps requesting Graph scopes.
- BEC operators using mailbox rules and internal reply-chain hijacking.
- MFA fatigue and social-engineering attacks that combine helpdesk pretexts with cloud-token abuse.
- Search, chat, and collaboration lures that move phishing away from traditional email-only delivery.

Defensive implication:

- Email security alone is insufficient. Coverage must include Entra ID sign-ins, app consent events, token/session revocation workflows, mailbox audit logs, and cloud app activity.

9. Indicators of Compromise

9.1 Indicator Summary

Indicator Class	Confidence	Recommended Use
Device-code sign-ins from unusual clients or locations	High	Primary detection and investigation pivot.
User entering device code after receiving unsolicited email/chat	High	Helpdesk and user-report triage.
New OAuth app consent with broad Graph scopes	High	App governance and consent review.
Mailbox rule creation after suspicious sign-in	High	BEC and stealth detection.
Token refresh/session activity from new geography or unmanaged device	Medium	Conditional access and session revocation.
Domains and URLs in phishing lures	Medium	Block/hunt if source-specific; refresh frequently.
File hashes	Low	Usually not relevant; this is identity-first tradecraft.

9.2 Behavioral Indicators

- Sign-in logs with client app or authentication protocol consistent with device-code flow.
- Login to Microsoft device verification endpoint shortly after a suspicious message.

- User successfully authenticates while source application/device does not match normal usage.
- Graph API access spike after initial sign-in.
- Mailbox access from unfamiliar IP, ASN, user agent, or device ID.
- Creation of inbox rules that move, delete, mark read, or forward messages.
- OAuth consent to application requesting `Mail.Read`, `Mail.ReadWrite`, `Files.Read.All`, `offline_access`, `User.Read`, `Mail.Send`, or similarly sensitive scopes.
- Successful sign-in followed by internal phishing from the same mailbox.
- Refresh-token use after user password reset but before session revocation.

9.3 IOC Usage Guidance

Do not over-index on domains or URLs for this campaign. Device-code phishing commonly uses legitimate Microsoft endpoints and short-lived lure infrastructure. The most durable indicators are:

- Tenant audit events.
- OAuth app consent records.
- Sign-in risk and user risk events.
- Device compliance state.
- Mailbox audit operations.
- Graph activity.

10. MITRE ATT&CK Mapping

Technique	Name	Applicability	Evidence / Rationale
T1566	Phishing	High	Initial lure delivered by email or collaboration channel.
T1566.002	Spearphishing Link	High	Users are directed to login or device-code verification flow.
T1204	User Execution	Medium	User action is required to enter the code and complete login.
T1078.004	Valid Accounts: Cloud Accounts	High	Stolen OAuth tokens enable cloud-account access.
T1528	Steal Application Access Token	High	Core objective is token acquisition.
T1550.001	Use Alternate Authentication Material: Application Access Token	High	Attackers use tokens instead of passwords.
T1098.005	Account Manipulation: Device Registration	Medium	Possible if attackers register devices or manipulate trusted state.
T1098.003	Account Manipulation: Additional Cloud Roles	Medium	Possible post-compromise action if privileges allow.
T1114.002	Email Collection: Remote Email Collection	High	Mailbox access is a common post-compromise objective.
T1114.003	Email Collection: Email Forwarding Rule	Medium	BEC actors often create stealthy mailbox rules.
T1530	Data from Cloud Storage	Medium	Access to Share-Point/OneDrive/Graph can expose documents.

Technique	Name	Applicability	Evidence / Rationale
T1586.003	Compromise Accounts: Cloud Accounts	Medium	Compromised accounts can be reused for later campaigns.

11. Detection Engineering

11.1 Detection Hypotheses

Hypothesis	Data Source	Expected Artifact
If a user falls for device-code phishing, Entra ID will show a device-code-style sign-in from an unusual client, IP, or device state.	Entra ID sign-in logs	Client/app anomaly, unfamiliar IP/ASN, unmanaged device.
If OAuth consent phishing succeeds, audit logs will show user or admin consent to a new application with sensitive scopes.	Entra audit logs / app consent logs	New service principal or consent grant.
If account takeover moves toward BEC, Exchange audit logs will show mailbox rule creation after suspicious sign-in.	Exchange Online audit logs	New-InboxRule, Set-InboxRule, forwarding, delete/hide rules.
If stolen tokens are used, session activity may continue after password reset until refresh tokens are revoked.	Entra sign-in logs / token events	Continued sign-ins or Graph activity after credential reset.

11.2 Microsoft Sentinel / Defender KQL - Device-Code and Token Abuse Triage

```
let lookback = 14d;
SigninLogs
| where TimeGenerated > ago(lookback)
| where ResultType == 0
| where ClientAppUsed has_any ("Mobile Apps and Desktop clients", "Browser")
  or AppDisplayName has_any ("Microsoft Authentication Broker", "Microsoft Office", "Microsoft Azure CLI", "Microsoft Graph Command
↵ Line Tools")
| extend DeviceManaged = tostring(DeviceDetail.isManaged), DeviceCompliant = tostring(DeviceDetail.isCompliant)
| where DeviceManaged != "true" or DeviceCompliant != "true" or RiskLevelAggregated != "none"
| project TimeGenerated, UserPrincipalName, AppDisplayName, ClientAppUsed, IPAddress, Location, UserAgent, DeviceManaged,
↵ DeviceCompliant, RiskLevelAggregated, ConditionalAccessStatus, CorrelationId
| order by TimeGenerated desc
```

Validation:

- Baseline legitimate developer and admin device-code usage such as Azure CLI, Graph CLI, Teams devices, and PowerShell.
- Alert higher when the user received a suspicious email/chat within 30 minutes of the sign-in.
- Alert higher for unmanaged devices, unfamiliar countries, impossible travel, or nonstandard user agents.

11.3 Microsoft Sentinel KQL - New OAuth Consent With Sensitive Scopes

```
let SensitiveScopes = dynamic(["Mail.Read", "Mail.ReadWrite", "Mail.Send", "Files.Read", "Files.Read.All", "Sites.Read.All",
↵ "offline_access", "User.Read.All", "Directory.Read.All"]);
AuditLogs
| where TimeGenerated > ago(30d)
| where OperationName has_any ("Consent to application", "Add delegated permission grant", "Add app role assignment to service
↵ principal", "Add service principal")
```

```
| mv-expand TargetResources
| extend AppName = tostring(TargetResources.displayName)
| extend ModifiedProperties = tostring(TargetResources.modifiedProperties)
| where ModifiedProperties has_any (SensitiveScopes)
| project TimeGenerated, OperationName, InitiatedBy, AppName, ModifiedProperties, Result, CorrelationId
| order by TimeGenerated desc
```

Validation:

- Compare against approved enterprise applications.
- Confirm publisher verification status and app owner.
- Review whether consent was user-consent or admin-consent.

11.4 Microsoft 365 Defender KQL - Suspicious Mailbox Rule After Risky Sign-In

```
let SuspiciousSignins =
    AADSignInEventsBeta
    | where Timestamp > ago(14d)
    | where ErrorCode == 0
    | where RiskLevelDuringSignIn in ("medium", "high") or IsManaged == 0 or IsCompliant == 0
    | project AccountUpn, SigninTime=Timestamp, IPAddress, Application, Country;
CloudAppEvents
| where Timestamp > ago(14d)
| where ActionType in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules", "Set-Mailbox")
| join kind=inner SuspiciousSignins on $left.AccountId == $right.AccountUpn
| where Timestamp between (SigninTime .. SigninTime + 24h)
| project Timestamp, AccountId, ActionType, Application, IPAddress, Country, RawEventData
```

11.5 Sigma - Suspicious OAuth Consent Grant

```
title: Suspicious OAuth Consent Grant With Sensitive Mail Or File Scopes
id: f6399a10-b0ef-4a5d-88fb-4d602ccdd365
status: experimental
description: Detects new OAuth consent grants involving sensitive Microsoft Graph scopes often abused after OAuth phishing.
author: Lost Boys Cyber
date: 2026-06-03
references:
  - https://www.microsoft.com/security/blog/
  - https://attack.mitre.org/techniques/T1528/
tags:
  - attack.credential_access
  - attack.t1528
  - attack.defense_evasion
  - attack.t1550.001
logsource:
  product: azure
  service: auditlogs
detection:
  selection_operation:
    OperationName|contains:
    - "Consent to application"
    - "Add delegated permission grant"
    - "Add app role assignment to service principal"
  selection_scope:
    TargetResources|contains:
    - "Mail.Read"
    - "Mail.ReadWrite"
    - "Mail.Send"
    - "Files.Read.All"
    - "Sites.Read.All"
    - "offline_access"
  condition: selection_operation and selection_scope
falsepositives:
  - Approved enterprise application onboarding
  - Legitimate admin consent during SaaS deployment
level: high
```

11.6 Tuning and Deployment Notes

- Build an allowlist of approved apps, app IDs, publishers, and normal consent workflows.
- Require admin approval workflow for new high-impact delegated permissions.
- Alert on user consent where admin consent is expected.
- Retain sign-in and audit logs long enough to investigate token abuse after delayed discovery.
- Pair detection with automated session revocation and app-consent removal playbooks.

12. Threat Hunting

Hunt 1 - Device-Code Sign-In After Suspicious Message

Hypothesis:

- A user who received a suspicious “meeting,” “document,” or “security validation” message completed a device-code flow shortly afterward.

Data:

- EmailEvents, EmailUrlInfo, Teams audit logs, Entra SigninLogs.

Pivot:

- Suspicious email time +/- 60 minutes.
- User sign-in to Microsoft apps from unfamiliar IP, unmanaged device, or unexpected client.

Triage:

- Ask the user whether they entered a device code.
- Review session token activity.
- Revoke sessions if confirmed.

KQL hunt query:

```
let SuspiciousTerms = dynamic(["device code", "enter code", "verification code", "Microsoft Teams", "shared document", "secure
↪ document", "MFA validation", "security validation"]);
let MessageWindow = 60m;
let SuspiciousMessages =
    EmailEvents
    | where Timestamp > ago(14d)
    | where Subject has_any (SuspiciousTerms) or SenderDisplayName has_any ("Microsoft", "Teams", "SharePoint", "OneDrive",
↪ "Helpdesk", "IT Support")
    | project RecipientEmailAddress, MessageTime=Timestamp, Subject, SenderFromAddress, NetworkMessageId;
SigninLogs
| where TimeGenerated > ago(14d)
| where ResultType == 0
| where AppDisplayName has_any ("Microsoft Authentication Broker", "Microsoft Office", "Microsoft Azure CLI", "Microsoft Graph
↪ Command Line Tools")
    or ClientAppUsed has_any ("Mobile Apps and Desktop clients", "Browser")
| extend Managed = tostring(DeviceDetail.isManaged), Compliant = tostring(DeviceDetail.isCompliant)
| where Managed != "true" or Compliant != "true" or RiskLevelAggregated != "none"
| join kind=inner SuspiciousMessages on $left.UserPrincipalName == $right.RecipientEmailAddress
| where TimeGenerated between (MessageTime .. MessageTime + MessageWindow)
| project TimeGenerated, UserPrincipalName, AppDisplayName, ClientAppUsed, IPAddress, Location, Managed, Compliant,
↪ RiskLevelAggregated, Subject, SenderFromAddress, NetworkMessageId, CorrelationId
| order by TimeGenerated desc
```

Splunk SPL hunt query:

```
index=o365 earliest=-14d
(
    sourcetype="azure:signin" OR sourcetype="o365:management:activity"
)
(
    appDisplayName="Microsoft Authentication Broker"
    OR appDisplayName="Microsoft Office"
    OR appDisplayName="Microsoft Azure CLI"
    OR clientAppUsed="Mobile Apps and Desktop clients"
)
```

```
(
  riskLevelAggregated!="none"
  OR deviceDetail.isManaged!="true"
  OR deviceDetail.isCompliant!="true"
)
| table _time userPrincipalName appDisplayName clientAppUsed ipAddress location deviceDetail.isManaged deviceDetail.isCompliant
↪ riskLevelAggregated correlationId
```

Hunt 2 - New OAuth App With Broad Scopes

Hypothesis:

- An attacker obtained user/admin consent to a malicious or suspicious app after phishing.

Data:

- AuditLogs, ServicePrincipalSignInLogs, App governance, Entra enterprise applications.

Pivot:

- New service principals in the last 30 days.
- Delegated permissions containing mail, files, sites, directory, or `offline_access`.

Triage:

- Confirm app publisher, redirect URIs, consent grant type, owner, and last sign-in.
- Remove grants and service principal if unauthorized.

KQL hunt query:

```
let SensitiveScopes = dynamic(["Mail.Read", "Mail.ReadWrite", "Mail.Send", "Files.Read", "Files.Read.All", "Sites.Read.All",
  ↪ "offline_access", "User.Read.All", "Directory.Read.All"]);
AuditLogs
| where TimeGenerated > ago(30d)
| where OperationName has_any ("Consent to application", "Add delegated permission grant", "Add app role assignment to service
  ↪ principal", "Add service principal", "Update application")
| mv-expand TargetResources
| extend AppName = tostring(TargetResources.displayName)
| extend ResourceType = tostring(TargetResources.type)
| extend ModifiedProperties = tostring(TargetResources.modifiedProperties)
| where ModifiedProperties has_any (SensitiveScopes)
| extend Actor = coalesce(tostring(InitiatedBy.user.userPrincipalName), tostring(InitiatedBy.app.displayName))
| project TimeGenerated, OperationName, Actor, AppName, ResourceType, ModifiedProperties, Result, CorrelationId
| order by TimeGenerated desc
```

Splunk SPL hunt query:

```
index=o365 earliest=-30d sourcetype="azure:audit"
(
  operationName="Consent to application"
  OR operationName="Add delegated permission grant"
  OR operationName="Add app role assignment to service principal"
  OR operationName="Add service principal"
)
(
  "Mail.Read" OR "Mail.ReadWrite" OR "Mail.Send" OR "Files.Read.All" OR "Sites.Read.All" OR "offline_access" OR "Directory.Read.All"
)
| table _time operationName initiatedBy.user.userPrincipalName initiatedBy.app.displayName targetResources{}.displayName
↪ targetResources{}.modifiedProperties result correlationId
```

Hunt 3 - Mailbox Rule And Forwarding Abuse

Hypothesis:

- Post-compromise actors used mailbox rules to hide fraud or forward data.

Data:

- Exchange Online audit logs, CloudAppEvents, mailbox settings.

Pivot:

- Inbox rules created after suspicious sign-in.
- Forwarding to external addresses.
- Rules that delete, move, or mark messages as read.

Triage:

- Export rules before deletion for evidence.
- Search for payment, invoice, wire, HR, payroll, and MFA keywords.

KQL hunt query:

```
let RuleActions = dynamic(["New-InboxRule", "Set-InboxRule", "UpdateInboxRules", "Set-Mailbox", "Add-MailboxPermission"]);
let SuspiciousRuleTerms = dynamic(["forward", "redirect", "delete", "markasread", "mark as read", "move", "junk", "archive",
↪ "invoice", "wire", "payment", "mfa", "password"]);
CloudAppEvents
| where Timestamp > ago(30d)
| where ActionType has_any (RuleActions)
| extend Raw = tostring(RawEventData)
| where Raw has_any (SuspiciousRuleTerms) or ActionType in ("New-InboxRule", "Set-InboxRule", "Set-Mailbox")
| project Timestamp, AccountId, ActionType, Application, IPAddress, UserAgent, RawEventData
| order by Timestamp desc
```

Correlation KQL:

```
let RiskySignins =
    SigninLogs
    | where TimeGenerated > ago(30d)
    | where ResultType == 0
    | extend Managed = tostring(DeviceDetail.isManaged), Compliant = tostring(DeviceDetail.isCompliant)
    | where RiskLevelAggregated != "none" or Managed != "true" or Compliant != "true"
    | project UserPrincipalName, SigninTime=TimeGenerated, IPAddress, Location, RiskLevelAggregated;
CloudAppEvents
| where Timestamp > ago(30d)
| where ActionType in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules", "Set-Mailbox")
| join kind=inner RiskySignins on $left.AccountId == $right.UserPrincipalName
| where Timestamp between (SigninTime .. SigninTime + 24h)
| project Timestamp, AccountId, ActionType, SigninTime, IPAddress, Location, RiskLevelAggregated, RawEventData
```

Splunk SPL hunt query:

```
index=o365 earliest=-30d
(
    Operation="New-InboxRule"
    OR Operation="Set-InboxRule"
    OR Operation="UpdateInboxRules"
    OR Operation="Set-Mailbox"
)
("forward" OR "redirect" OR "delete" OR "markasread" OR "move" OR "invoice" OR "wire" OR "payment" OR "mfa")
| table _time UserId Operation ClientIP UserAgent Parameters
```

Hunt 4 - Internal Phishing From Compromised Accounts

Hypothesis:

- Attackers used a compromised mailbox to phish internal users with high trust.

Data:

- EmailEvents, Threat Explorer, message trace, Entra sign-ins.

Pivot:

- Sudden outbound volume from compromised account.
- Internal recipients receiving device-code, document, or Teams-themed lures.

Triage:

- Pull messages, purge if needed, notify recipients, revoke sessions.

KQL hunt query:

```
let LureTerms = dynamic(["device code", "verification code", "enter this code", "Teams meeting", "shared document", "OneDrive",
  ↳ "SharePoint", "secure file", "MFA validation"]);
EmailEvents
| where Timestamp > ago(14d)
| where EmailDirection == "Outbound"
| where Subject has_any (LureTerms) or DeliveryAction has_any ("Delivered", "Junked")
| summarize RecipientCount=count(RecipientEmailAddress), Subjects=make_set(Subject, 10), FirstSeen=min(Timestamp),
  ↳ LastSeen=max(Timestamp) by SenderFromAddress, SenderIPv4
| where RecipientCount >= 10
| order by RecipientCount desc, LastSeen desc
```

Internal-recipient KQL pivot:

```
let InternalDomain = "example.com";
let LureTerms = dynamic(["device code", "verification code", "enter this code", "Teams meeting", "shared document", "secure file"]);
EmailEvents
| where Timestamp > ago(14d)
| where EmailDirection == "Outbound"
| where RecipientEmailAddress endswith strcat("@", InternalDomain)
| where Subject has_any (LureTerms)
| project Timestamp, SenderFromAddress, RecipientEmailAddress, Subject, NetworkMessageId, SenderIPv4, DeliveryAction
| order by Timestamp desc
```

Splunk SPL hunt query:

```
index=o365 earliest=-14d sourcetype="o365:message_trace"
direction="Outbound"
("device code" OR "verification code" OR "enter this code" OR "Teams meeting" OR "shared document" OR "secure file")
| stats dc(recipient) as recipient_count values(subject) as subjects min(_time) as first_seen max(_time) as last_seen by sender src_ip
| where recipient_count >= 10
| convert ctime(first_seen) ctime(last_seen)
| sort - recipient_count
```

13. Impact Assessment

Business impact:

- Unauthorized mailbox access.
- Sensitive document exposure through SharePoint, OneDrive, Teams, and Graph.
- Internal phishing from trusted accounts.
- BEC, invoice fraud, payroll diversion, and vendor-payment manipulation.
- Regulatory exposure if personal or regulated data is accessed.
- Long-lived access if refresh tokens and OAuth grants are not revoked.

Technical impact:

- Password reset alone may not remove attacker access.
- MFA does not fully protect users who authorize the attacker's device flow.
- Device-code flows can blend into legitimate authentication unless monitored.
- OAuth app consent can create durable access paths outside normal mailbox sign-in patterns.

Risk rating:

- High for Microsoft 365 tenants with weak conditional access, user app consent enabled, limited device-code monitoring, or high BEC exposure.
- Medium for tenants with strong phishing-resistant MFA, managed-device requirements, admin consent workflow, and mature identity monitoring.

14. Recommended Actions

Priority	Owner	Timeline	Action
Critical	Identity / Entra Admin	24 hours	Review and restrict OAuth device-code authentication where business use is not required.
Critical	Identity / Entra Admin	24 hours	Enforce conditional access requiring compliant or managed devices for sensitive apps.
Critical	Identity / Entra Admin	24 hours	Disable broad user consent to apps; use admin consent workflow for sensitive permissions.
High	SOC	48 hours	Deploy detections for suspicious device-code sign-ins, new OAuth grants, and mailbox rules after risky sign-ins.
High	SOC / IR	48 hours	Build an account-takeover playbook that revokes sessions, refresh tokens, and OAuth grants, not just passwords.
High	Messaging Team	48 hours	Tune email security for AI-generated lure patterns, brand spoofing, and device-code language.
High	Exchange Admin	72 hours	Hunt for suspicious inbox rules, forwarding settings, and mailbox delegation changes.
Medium	Security Awareness	1 week	Train users that legitimate Microsoft pages can still be abused if they enter a code from an unsolicited message.
Medium	App Governance	1 week	Inventory service principals, app owners, publisher verification, and high-risk Graph scopes.
Medium	GRC / Legal	2 weeks	Add OAuth-token compromise and BEC scenarios to incident reporting and evidence-preservation procedures.

Recommended control baseline:

- Phishing-resistant MFA for administrators and high-risk users.
- Conditional access requiring managed/compliant devices for Microsoft 365.
- Disable or tightly scope device-code flow if not operationally required.
- Admin consent workflow for app permissions.
- App governance for sensitive OAuth scopes.

- Continuous access evaluation and session revocation playbooks.
- Mailbox audit logging enabled and retained.
- Entra ID Protection and risky sign-in investigation workflows.

15. Sources & References

- Microsoft Security Blog, “AI-enabled device code phishing campaign”, 2026-04-06. <https://www.microsoft.com/en-us/security/blog/2026/04/06/ai-enabled-device-code-phishing-campaign-april-2026/>
- FBI IC3, “Kali365: Cybercriminals Use Artificial Intelligence to Facilitate Phishing Campaigns”, PSA260521, 2026-05-21. <https://www.ic3.gov/PSA/2026/PSA260521>
- Microsoft Learn, “OAuth 2.0 device authorization grant flow”. <https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-device-code>
- Microsoft Learn, “Configure the admin consent workflow”. <https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-admin-consent-workflow>
- Microsoft Learn, “Manage user consent to applications”. <https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-user-consent>
- MITRE ATT&CK, T1528 “Steal Application Access Token”. <https://attack.mitre.org/techniques/T1528/>
- MITRE ATT&CK, T1550.001 “Use Alternate Authentication Material: Application Access Token”. <https://attack.mitre.org/techniques/T1550/001/>
- MITRE ATT&CK, T1078.004 “Valid Accounts: Cloud Accounts”. <https://attack.mitre.org/techniques/T1078/004/>
- MITRE ATT&CK, T1566.002 “Phishing: Spearphishing Link”. <https://attack.mitre.org/techniques/T1566/002/>
- CISA, “Implementing Phishing-Resistant MFA”. <https://www.cisa.gov/resources-tools/resources/implementing-phishing-resistant-mfa>
- NSA and CISA, cloud and identity hardening guidance, used for defensive control context. <https://www.cisa.gov/>

Refresh notes:

- Re-check Microsoft and FBI reporting before operational briefings because named campaigns, infrastructure, and PhaaS branding can change quickly.
- Verify whether the tenant legitimately uses device-code authentication before disabling it globally.
- Validate all KQL against the tenant’s available table schema; Microsoft Defender and Sentinel table names can differ by connector and licensing.